Google Cloud

Working with Cloud Audit Logs

In this module, we investigate the core Cloud Audit Logs that Google Cloud collects.

Objectives

01 Explain Cloud Audit Logs.

02 List and explain different audit logs.

03 Explain the features and functionalities of the different audit logs.

04 List the best practices to implement audit logs.

In this module, you'll learn to:

- Explain Cloud Audit Logs.
- List and explain different audit logs.
- Explain the features and functionalities of the different audit logs.
- List the best practices to implement audit logs.

In this section, you explore

- Cloud Audit Logs
- Data Access audit logs
- Audit logs entry format
- Best practices

We start with an overview of what audit logs do for us. Then we move to using the optional Data Access audit logs, explore the format of audit log entries, and wrap up with some logging best practices.

In terms of sheer volume of useful information, probably the most important group of logs in Google Cloud are the Cloud Audit Logs.

Cloud Audit Logs: “Who did what, where, and when?”

- Admin Activity audit logs.
- System Event audit logs
- Data Access audit logs
- Policy Denied audit logs

Cloud Audit Logs helps answer the question, "Who did what, where, and when?”

It maintains four audit logs for each Google Cloud project, folder, and organization:

- **Admin Activity audit logs**
- **System Event audit logs**
- **Data Access audit logs**
- **Policy Denied audit logs**

All Google Cloud services will eventually provide audit logs. For now, see the Google services with audit logs documentation for coverage details.

Cloud Audit Logs: “Who did what, where, and when?”

Admin Activity audit logs	System Event audit logs	Data Access audit logs	Policy Denied audit logs
Record modifications to configuration or metadata.	Record Google Cloud non-human admin actions that modify configurations.	Record calls that read metadata, configurations, or that create, modify, or read user-provided data.	Record a security policy violation.

Admin Activity audit logs contain log entries for API calls or other administrative actions that modify the configuration or metadata of resources. For example, these logs record when users create VM instances or change Identity and Access Management permissions.

- They are always on, are retained for 400 days, and are available at no charge.
- To view these logs, you must have the IAM role **Logging/Logs Viewer** or **Project/Viewer**.

System Event audit logs contain log entries for Google Cloud administrative actions that modify the configuration of resources.

- System Event audit logs are generated by Google systems; they are not driven by direct user action.
- They are always enabled, free, and retained for 400 days.
- To view these logs, you must have the IAM role **Logging/Logs Viewer** or **Project/Viewer**.

Data Access audit logs contain API calls that read the configuration or metadata of resources. Also, user-driven API calls that create, modify, or read user-provided resource data.

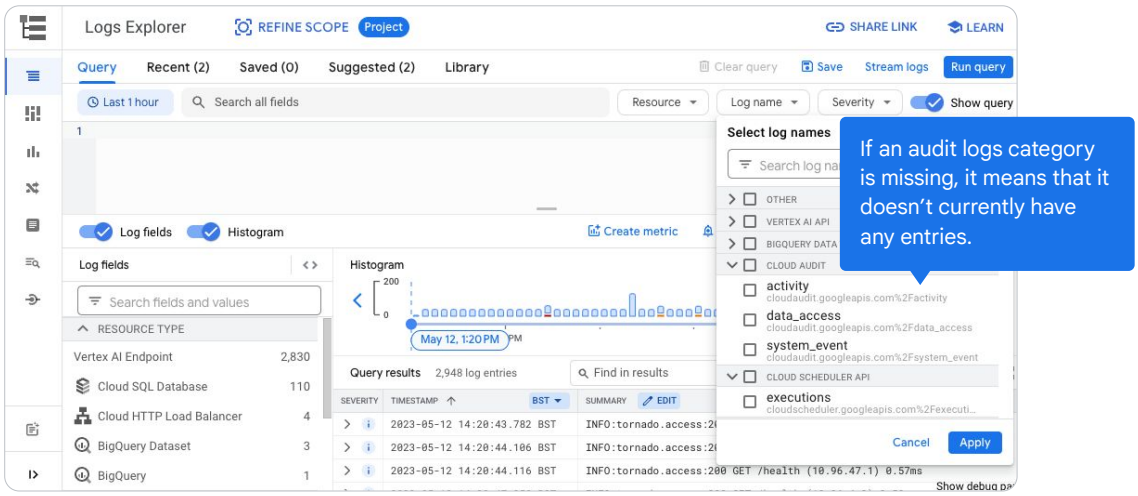
- Data Access audit logs don’t record the data-access operations on resources that are publicly shared (available to **All Users** or **All Authenticated Users**).

- Data Access audit logs also don’t record the data-access operations on resources that can be accessed without logging into Google Cloud.
- They are disabled by default (except for BigQuery), and when enabled, the default retention is 30 days.
- To view these logs, you must have the IAM roles **Logging/Private Logs Viewer** or **Project/Owner**.

When a security policy is violated, policy denied audit logs records when access to a user or service account is denied by Google Cloud service.

- Policy Denied audit logs are generated by default and your Google Cloud project is charged for the logs storage.
- You can't disable Policy Denied audit logs. However, you can use exclusion filters to prevent Policy Denied audit logs from being ingested and stored in Cloud Logging.

Filtering audit logs



To view and filter audit logs:

1. Navigate to Logs Explorer
2. Filter by using the **Log name** drop-down menu.
   Note: typing *cloudaudit* into the filter box is frequently quicker than scrolling.

If one of the four audit logs is missing, that simply means it doesn't currently have any entries.

The example here filters the logs by a project and you can select the log entries you would like to audit.

You can even use the query builder to filter audit logs. This query is auto populated in the query section when using the UI. For details check out the [documentation] page.

Access Transparency logs

Show **how** and **why** customer data is accessed after it is stored in Google Cloud.

	Log access actions.
	Track actions by Google personnel.
	Support approval and events are surfaced through Security Command Center and apps' APIs and UIs.

Whether it's a hardware support engineer, or a rep working on a ticket, having dedicated experts manage parts of the infrastructure is a key benefit of operating in Google Cloud.

- Very similar to Cloud Audit logs, Access Transparency logs help by providing logs of accesses to your data by human Googlers (as opposed to automated systems).
- Enterprises with appropriate support packages can enable the logs, and receive the log events in near-real time. The log events are surfaced through the APIs, Cloud Logging, and Security Command Center.

Access Transparency logs give you different information than Cloud Audit Logs. Cloud Audit Logs record the actions that members of your Google Cloud organization have taken in your Google Cloud resources, whereas Access Transparency logs record the actions taken by Google personnel.

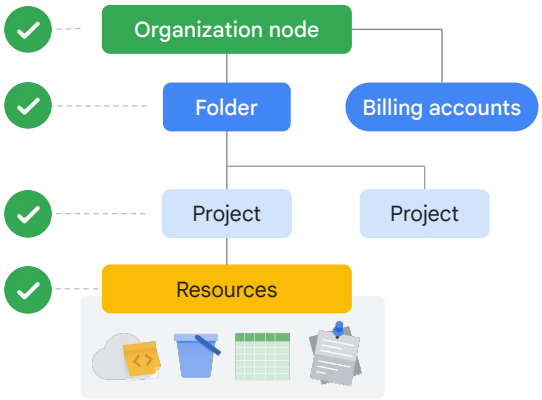
In this section, you explore

- Cloud Audit Logs
- Data Access audit logs
- Audit logs entry format
- Best practices

Let’s continue by looking at Data Access audit logs.

Enabling Data Access audit logs in the organization

- Data Access audit logs can be enabled at different levels:
  - Organization
  - Folder
  - Project
  - Resources
  - Billing accounts
- You can even exempt principals from recording data access logs.
- Final scope is the union of the configurations.



Data Access audit logs can be enabled at various levels in the resource hierarchy. These levels include:

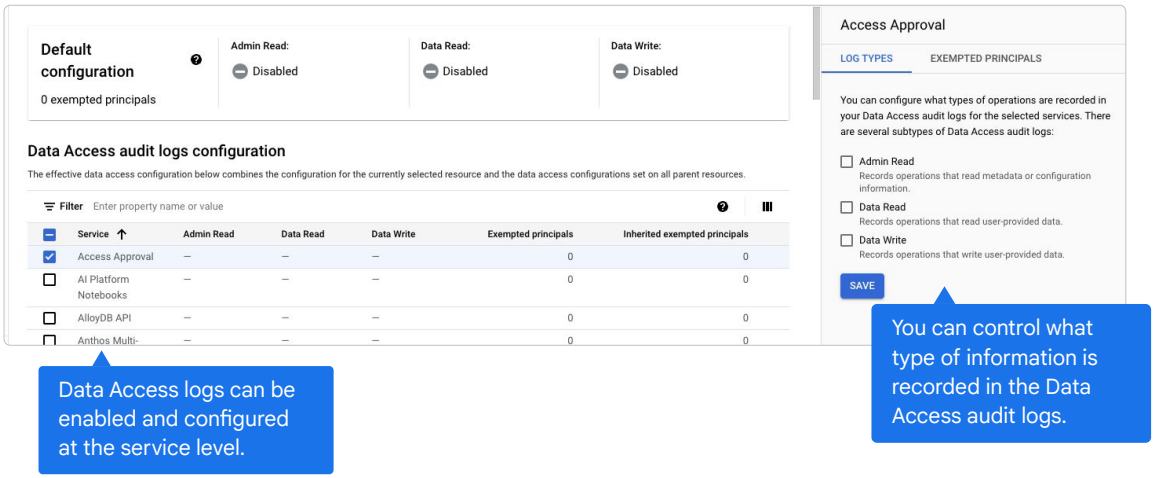
- Organization
- Folder
- Project,
- Resources, and
- Billing accounts

You can also exempt principals from recording data access logs.

The final configuration of Data Access audit logs is the union of the configurations. For example, at a project level, you can enable logs for a Google Cloud service. But you can't disable logs for a Google Cloud service that is enabled in a parent organization or folder.

The added logging does add to the cost, currently: $0.50 per gigabyte for ingestion.

Enabling Data Access access logs per Google Cloud service



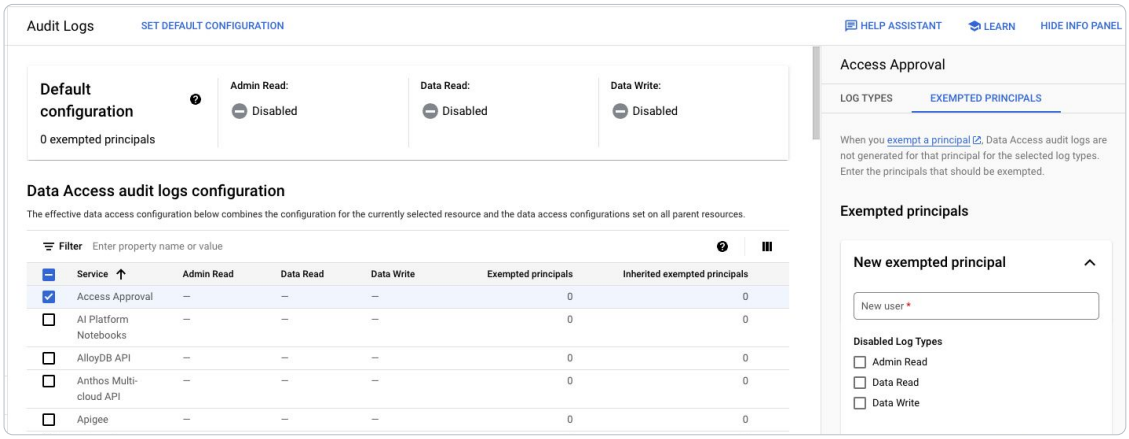
Data Access audit logs are disabled by default, for everything but BigQuery. They may be enabled and configured at the organization, folder, project, or service level.

You can control what type of information is kept in the audit logs.

There are three types of Data Access audit logs information:

- **Admin-read** records operations that read metadata or configuration information. For example, you looked at the configurations for your bucket.
- **Data-read** records operations that read user-provided data. For example, you listed files and then downloaded one from Cloud Storage.
- **Data-write r**ecords operations that write user-provided data. For example, you created a new Cloud Storage file.

Exempt specific users or groups



You can exempt specific users or groups from having their data accesses recorded. This functionality is useful when you want to reduce the cost and noise associated with the volume of logs that are not of your interest. Data Access audit logs can be of high volume, so cost associated is directly proportional to the volume of data logs.

Programmatically enabling Data Access audit logs

Step 1

```
gcloud projects get-iam-policy [project-id] > policy.yaml
```

Step 2

```
auditConfigs:
- auditLogConfigs:
- logType: ADMIN_READ
  - logType: DATA_READ
  - logType: DATA_WRITE
  service: run.googleapis.com #Could also be all Services
bindings:
- members:
  ...
```

Step 3

```
gcloud projects set-iam-policy [project-id] policy.yaml
```

You can also use the Google Cloud CLI or the API to enable Data Access audit logs.

1. If you're using the gcloud CLI frequently, the easiest way is to get the current IAM policies, as seen in step 1, and write them to a file.
2. Then you can edit the /tmp/policy.yaml file to add or edit the auditLogConfigs. You can also add the log details per service, like this example is enabling logging for Cloud Run. You can even enable logging on all services.
3. Then, as seen in step 3, you would set that as the new IAM policy.

In this section, you explore

- Cloud Audit Logs
- Data Access audit logs
- **Audit logs entry format**
- Best practices

Now that you learned to enable the logs you need, let's examine the logging entries themselves.

Cloud Audit Log entries

```
{
 insertId: "-77e5fge38tyo"
 logName: "projects/<projectID>/logs/cloudaudit.googleapis.com%2Fdata_access"
 operation: {
   first: true
   id: "1581200795118:bquxjob_56996f5_17026e67aa2"
   producer: "bigquery.googleapis.com"
 }

 protoPayload: {
   @type: "type.googleapis.com/google.cloud.audit.AuditLog"
   authenticationInfo: {
     principalEmail: "cloudysanfrancisco@gmail.com"
   }
```

Identify an audit log type by looking at the **logName** field.

Identify the resource generating log by looking at the **producer** field.

Identify an audit log entry by looking at the **protoPayload** field.

Identify the principal generating log by looking at the **principalEmail** field.

Every audit log entry in Cloud Logging is an object of type LogEntry.

What distinguishes an audit log entry from other log entries is the protoPayload field, which contains an AuditLog object that stores the audit logging data.

Note the log name, which tells us that we're looking at an example from Data Access audit logs.

Identify the principal generating log by looking at the principalEmail.

The operation field only exists for a large or long-running audit log entries.

Google has a standard List of official service names. You can use this list as a handy reference.

Cloud Audit Log entries


```
 authorizationInfo: [2]
 methodName: "jobservice.getqueryresults"
 requestMetadata: {…}
 resourceName: "projects/<project_ID>/queries/bquxjob_1eb1f384_17026e9d185"
 serviceData: {…}
 serviceName: "bigquery.googleapis.com"
 status: {…} }
 receiveTimestamp: "2020-02-08T22:27:06.410866127Z"
 resource: {
  labels: { project_id: "<project_ID>", op_unit: "USA"
  }
  type: "bigquery_resource"
 }
 severity: "INFO"
 timestamp: "2020-02-08T22:27:05.908Z"
}
```


On this slide, you can tell we're looking at a query that was run in BigQuery.

If you expanded the serviceData field, you could actually see the query itself.

So, when someone at your organization runs that unexpected, $40,000 query, you can see who ran it and what the query was.

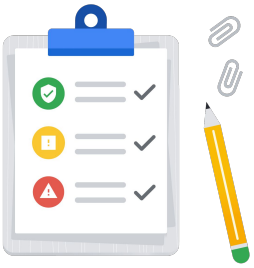
In this section, you explore

- Cloud Audit Logs
- Data Access audit logs
- Audit logs entry format
- Best practices

Let’s go over a few best practices before finishing this module.

Plan and create test projects

- Create a plan for Data Access audit logs.
- Create a test project and test plan.
- Roll out the plan.



Like anything in the cloud, start by planning first.

Spend time and create a solid plan for Data Access audit logs. Think organization, folder, then project. Like most organizations, some of your projects will be very specialized, but usually, they do break down into common organizational types.

Then, create a test project and experiment to see if the logging works the way you expect.

Then roll out the plan, and don't forget automation (Infrastructure as Code).

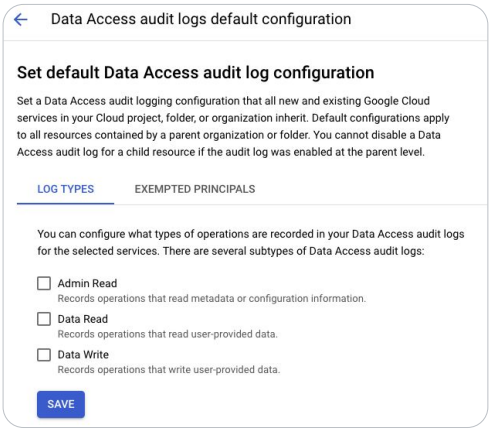
Determine and set organization-level data access

Advantages:

- Detailed information on who accessed, edited, or deleted what and when
- Free tier
- Some free logs

Disadvantage:

- Logs can be large and the queries per second can be high based on the number of data access requests.



Remember that Data Access audit logs can be enabled as high as the organization level.

The advantage would be detailed information on exactly who accessed, edited, and deleted what, and when.

The disadvantage is that Data Access logs can grow to be large, and are billed per gigabyte. This also results in higher queries per second based on the number of data access requests.

Infrastructure as Code (IaC)

- Run open source or pay for enterprise version.
- State can be stored locally or remote in Cloud Storage or Terraform Cloud.
- You can use Terraform to enable audit logs.
- Audit logs keep you informed of the resources provisioned using an IaC tool.

Infrastructure as Code (IaC) is essentially the process of automating the creation and modifications to your infrastructure using a platform. The platform supports configuration files, which can be put through a CI/CD (Continuous integration and continuous deployment) pipeline, like with code.

Terraform is an open source package from HashiCorp or paid for enterprise version.

It isn't hosted directly in Google Cloud, though it’s installed by default in Cloud Shell.

State management is a decision point for your organization. It can be remote or local.

Remote options include using Cloud Storage or Terraform Cloud. Local storage involves setting up something local to your organization, or using the pay-to-use HashiCorp Enterprise service.

Audit logs also inform you about the resources provisioned using an IaC tool. It is really useful if you want to control log sink filters at the project level. With terraform you can set default include/exclude filters and have them applied to every project.

Aggregate and store your organization's logs

- Centralize or subdivide log storage by creating user-defined buckets.
- Configure a default storage location at the organization level to automatically apply a region.
- Protect your audit logs storage by configuring customer-managed encryption keys (CMEK).

To manage your Google Cloud organization's logs, you can aggregate them from across your organization into a single Cloud Logging bucket.

It is recommended to create user-defined buckets to centralize or subdivide your log storage. Based on compliance and usage requirements, customize your logs storage by choosing where your logs are stored and defining the data retention period.

Some organization might have latency, compliance, and availability requirements in specific regions. Configure a default storage location to automatically apply a region in which buckets are created for log data.

By default, Cloud Logging encrypts customer content stored at rest. Your organization might have advanced encryption requirements that the default encryption at rest doesn't provide. To meet your organization's requirements, instead of Google managing the key encryption keys that protect your data, configure customer-managed encryption keys (CMEK) to control and manage your own encryption.

Plan and configure exports

- Decide on logs.
- Decide on level.
- Decide on filters.
- Consider the exclusions.

We've discussed the options and benefits of exporting logs. Again, make this part of your plan. Start by deciding what, if anything, you will export from Aggregated Exports at the organization level.

Next, decide what options you will use, project by project, folder by folder, and so on.

Then, carefully consider your filters—both what they leave in, and what they leave out. Filters apply to all logs, not just to exports.

Lastly, carefully consider what, if anything, you will fully exclude from logging. Remember that **excluded entries will be gone forever.**

Principle of least privilege

- Side-channel leakage of data through logs is a common issue.
- Plan the project to monitoring project relationships.
- Use appropriate IAM controls on both Google Cloud–based and exported logs.
- Data Access audit logs contain personally identifiable information (PII).

Side-channel leakage of data through logs is a common issue.

You need to be careful about who gets which kind of access and to which logs.

Remember some of the discussions earlier in this course on monitoring metrics scope? And how to monitor a current project?

That's where your security starts.

Are you monitoring project by project, or are you selectively grouping work projects into higher-level monitored projects?

Use appropriate IAM controls on both Google Cloud-based and exported logs, and only allow minimal access required to get the job done.

Especially scrutinize the Data Access audit log permissions, because they often contain Personally Identifiable Information (PII).

Configure log views

- Help control access to logs in a log bucket.
- Help control access specific to a project or a set of users.
- Help protect sensitive log data.

Log buckets store logs, including audit logs. Log views control access to logs in a log bucket. Custom log views can be created to control access to logs from specific projects or users. This helps protect sensitive data and ensures only authorized users have access.

Scenario: Operational monitoring

- CTO: resourcemanager.organizationAdmin
  - Assigns permissions to security team and service account.
- Security team: logging.viewer
  - Ability to view Admin Activity audit logs.
- Security team: logging.privateLogViewer
  - Ability to view Data Access audit logs.
- Assign all permissions at organization level.
- Control exported data access through Cloud Storage and BigQuery IAM roles.
- Use Sensitive Data Protection to redact PII.

Lastly, a few access scenarios, starting with operational monitoring.

Let's explore your high-level teams and assignments.
By job, a CTO will have the organization admin role, so they can assign permissions to the security team and service accounts.

The CTO can then give the security team logging.viewer so they can view the Admin Activity audit logs. Also, logging.privateLogViewer, so they can view the Data Access audit logs.

The view permissions are assigned at the organization level, so they are global. Access control to data exported to Cloud Storage or BigQuery will be secured selectively with IAM.

You might also want to explore Sensitive Data Protection to redact the PII. Data in the Data Access audit logs is deemed as personally identifiable information (PII) for this organization.

Integrating the application with Sensitive Data Protection gives the ability to redact sensitive PII data when viewing Data Access logs whether they are in the Data Access audit logs or from the historical archive in Cloud Storage.

Scenario: Development teams monitoring Audit Logs

- Security team remains the same:
  - logging.viewer, logging.privateLogViewer
- Dev team: logging.viewer at folder level
  - See Admin Activity audit logs by dev projects in folder.
- Dev team: logging.privateLogViewer at folder level
  - See Data Access audit logs.
- Use Cloud Storage or BigQuery IAM to control access to exported logs.
  - Providing a dashboard might be helpful.

Moving on to development teams.

The security team is unchanged from the last slide. They already have logging.viewer, and logging.privateLogViewer from the global assignment.

The development team might get logging.viewer at the folder level so they can see the Admin Activity audit logs for the projects within their development control.

They probably also need logging.privateLogViewer at the dev folder so they can see the Data Access audit logs. Limit data they test with though, so they aren't viewing actual customer information.

Again, use Cloud Storage or BigQuery IAM to control access to exported logs. Prebuilding dashboards might also be a good option.

Scenario: External auditors

- Provide pre-created dashboards for auditor usage.
- Provide Logs Viewer at organization level.
- Provide BigQuery Data Viewer at exported dataset.
    - Backend for dashboards.
- Use IAM and/or temporary access URLs for Cloud Storage.

For external auditors, provide pre-created dashboards where possible.

If they need broad access, you can make them with Logs Viewer role at the organization level.

For BigQuery, they could be **BigQuery Data Viewer** on the exported dataset.

For Cloud Storage, again, you could use IAM, but also remember the temporary access URLs that Cloud Storage supports.

Recap

01 Explain Cloud Audit Logs.

02 List and explain different audit logs.

03 Explain the features and functionalities of the different audit logs.

04 List the best practices to implement audit logs.

In this module, you learned to:

- Explain Cloud Audit Logs.
- List and explain different audit logs.
- Explain the features and functionalities of the different audit logs.
- List the Best Practices to implement audit logs.